

AN ECLECTIC TECHNOLOGIES REPORT

ERT Companion Proposal

AI-Enhanced Evidence Request Tool — NERC CIP Compliance Automation Initiative

Version 5.3 • March 2026

Tim Roxey

Eclectic Technologies

tim.roxey@gmail.com • 410.474.9240 (mobile/Signal)

SUGGESTED CITATION

T. Roxey, "ERT Companion Proposal," Version 5.3, Eclectic Technologies, March 2026.
DOI: <https://doi.org/10.5281/zenodo.21365218>

Executive Summary

Note: This tool does not replace the ERO Enterprise CIP ERT workbook. It automates population of the workbook, builds traceable evidence packages, and supports human-reviewed narrative responses.

This proposal outlines a pilot program to develop and validate an AI-enhanced Evidence Request Tool (ERT) system for NERC compliance audits. The pilot will use a mock-audit approach with volunteer utility and Regional Entity auditors to develop, test, and refine the system in a controlled environment before production deployment.

The current ERT process requires utilities to manually extract data from multiple internal systems and populate Excel-based worksheets. This manual approach is time-consuming, error-prone, and delivers limited value beyond satisfying immediate compliance requirements. An AI-enhanced system would automate data extraction, enable natural language querying, and extend the value of aggregated compliance data across multiple utility business functions.

The pilot program will span nine months and deliver a working prototype system, comprehensive documentation, security assessments, and a roadmap for production deployment. Success will be measured by demonstrable time savings (60–70% reduction in ERT completion time), improvements in data quality, and cross-functional utility adoption.

Key Benefits

- **Efficiency:** Reduce ERT completion time from 200–400 hours to 40–80 hours per audit cycle
- **Quality:** Automated data extraction reduces manual errors and ensures consistency
- **Value Extension:** Enable IT security, operations, procurement, and other business units to leverage compliance data
- **Audit Consistency:** Standardized data formats and automated processes improve consistency across Regional Entities
- **Continuous Compliance:** Year-round system operation enables proactive gap identification rather than reactive audit response

Background and Problem Statement

NERC Regulatory Framework

Under Section 215 of the Federal Power Act, NERC has statutory authority to develop and enforce Critical Infrastructure Protection (CIP) Reliability Standards for the North American bulk electric system. NERC delegates compliance monitoring to six Regional Entities that conduct audits of registered entities, including Asset Owner/Operators (AOOs), who are responsible for generation, transmission, and distribution facilities.

Current ERT Process

The Evidence Request Tool was developed in collaboration among NERC, Regional Entities, and industry representatives to standardize audit information requests and improve consistency across the ERO Enterprise. The ERT consists of Excel-based worksheets with Level 1 detail tabs that establish populations of assets, cyber systems, personnel, and security controls, followed by Level 2 detailed evidence requests for sampled items.

While the ERT has improved consistency compared to previous ad-hoc approaches, utilities face significant challenges in populating the worksheets because the required information resides across multiple internal systems, including facility databases, asset management systems, configuration management databases, work order systems, inventory control, SIEM platforms, human resources systems, training management, document management, and physical access control systems.

The Challenge

Current State Limitations:

- **Manual Data Extraction:** Compliance staff must query each source system individually, export data, and manually transpose it into ERT format
- **Time-Intensive Process:** Utilities report spending 200–400 hours per audit cycle on ERT completion, representing \$20,000–\$40,000 in labor costs
- **Error-Prone:** Manual transcription introduces data quality issues that require clarification cycles with audit teams
- **Limited Utility:** Once the audit concludes, the aggregated data is typically archived rather than leveraged for operational purposes
- **Reactive Posture:** Data is assembled only when an audit notification is received, missing opportunities for proactive compliance monitoring
- **Siloed Information:** Other utility business units cannot easily access compliance data that would inform their operations

Pilot Program Objectives

Primary Objectives

- **Develop and validate an AI-enhanced ERT system:** Create a working prototype with automated data extraction, dual GenAI interfaces, and credential-based access control
- **Execute mock audit:** Conduct a simulated compliance audit using the prototype system with real utility data and volunteer Regional Entity auditors
- **Validate efficiency gains:** Quantify time savings, data quality improvements, and user satisfaction compared to the manual baseline
- **Assess security and reliability:** Conduct an independent security assessment covering infrastructure and AI-specific vulnerabilities
- **Document implementation requirements:** Create a utility implementation playbook and technical specifications for broader deployment
- **Develop production roadmap:** Define the path from pilot to industry-wide adoption, including the regulatory approval pathway

Secondary Objectives

- Demonstrate cross-functional value proposition by enabling non-compliance business units to query aggregated data
- Identify integration challenges with varying utility IT architectures and develop mitigation strategies
- Establish quality assurance framework and validation methodologies for AI-generated compliance evidence
- Build industry confidence in AI-enabled compliance tools through transparent testing and documentation

Pilot Structure and Approach

Mock Audit Rationale

The pilot employs a mock-audit approach rather than conducting an actual compliance audit for several critical reasons. Most importantly, issues with the prototype system cannot affect the utility's actual compliance status or result in violations, thereby eliminating regulatory risk for the volunteer utility. This controlled environment allows parameters to be adjusted and scenarios replayed without real-world consequences, enabling iterative refinement that would be impossible during a live audit. The flexibility extends to audit timeline and scope, which can be adapted to pilot development needs rather than being constrained by regulatory requirements. This creates a learning-focused environment where participants can focus on system development and process refinement rather than compliance outcomes. Finally, using historical audit data from a recently completed audit cycle enables a direct comparison between manual and AI-assisted approaches, providing quantifiable validation of the system's efficiency gains and data-quality improvements.

Mock Audit Scenario Definition

The mock audit will simulate a comprehensive CIP compliance audit covering the full spectrum of Critical Infrastructure Protection standards from CIP-002 through CIP-013, ensuring complete coverage of the ERT detail tab. The audit will examine a historical three-year period from a recently completed audit cycle, such as January 2022 through December 2024, allowing direct comparison with actual audit results while eliminating compliance risk.

The simulated utility will maintain an asset inventory of 10–15 BES Assets spanning the full range of facility types, including control centers, substations, generation facilities, and black start resources, with varying impact levels to test all aspects of the ERT system. The cyber systems population will be representative of real-world utility environments, including high-impact BES Cyber Systems, medium-impact systems both with and without External Routable Connectivity, and low-impact BES Cyber Systems.

To ensure the mock audit adequately tests the system's capabilities, the scenario will incorporate complexity and edge cases that commonly arise in real-world audits. These include assets commissioned or decommissioned during the audit period, personnel transfers and terminations, vendor transitions, activations of cybersecurity incident response plans, and procurement activities for high- and medium-impact systems. If possible, the pilot will select a multi-regional utility to validate the system's ability to maintain consistency across different Regional Entity approaches and audit methodologies.

Alignment with CIP ERT Workflow

The pilot system explicitly supports the NERC CIP ERT v9 request ID structure and workbook organization, ensuring all outputs conform to the formats, naming conventions, and validation rules expected by Regional Entity auditors. The system architecture accommodates future ERT versions via configuration-based templates rather than hard-coded formats, supporting v10, v11, and subsequent releases as NERC adds new requirements such as CIP-003-9, CIP-012-2, and other evolving standards. This version-aware

design ensures that utilities adopting the system will not incur reimplementations costs whenever NERC updates the ERT workbook structure.

The system's design reflects the fundamental structure governing NERC compliance audits: the distinction between Level 1 and Level 2 evidence; the progression from population establishment through sample selection to detailed implementation review; and the Request for Information exchanges that clarify questions and resolve discrepancies throughout the audit lifecycle. By aligning the pilot's architecture with these established audit mechanics, the system integrates seamlessly into existing compliance workflows rather than requiring utilities or auditors to adapt to unfamiliar processes.

Level 1 Evidence establishes the foundation of the audit response. The system automates population of detail tabs that create complete inventories of BES Assets, Cyber Assets with appropriate classifications (BCA, EACMS, PACS, PCA), Electronic Security Perimeters, Electronic Access Points, Physical Security Perimeters, personnel with CIP training and access authorization, BCSi documentation, cybersecurity incidents, procurement activities, and reuse or disposal events. These populations must be defensible—meaning every entry can be traced back to authoritative source systems with documented provenance, every classification decision follows explicit business rules, and every count reconciles with operational reality. The ETL programs that extract data from utility source systems implement validation logic that flags potential inconsistencies before submission, enabling compliance staff to review and resolve issues rather than discovering them during auditor questioning. Alongside population data, Level 1 includes program and procedure evidence demonstrating that the utility has established the governance frameworks, security controls, and operational processes required by CIP standards. The system indexes these documents and links them to the relevant detail tabs, creating a complete Level 1 package that auditors can review to understand the utility's compliance posture and make informed sampling decisions.

Level 2 Evidence demonstrates implementation for items selected from Level 1 populations. Once auditors select samples—typically specific cyber assets, personnel records, vendor relationships, or incident responses for detailed review—the utility must assemble evidence demonstrating that the programs and procedures documented in Level 1 were implemented for those items. The system supports this phase by maintaining bidirectional links between population records and supporting artifacts. When an auditor selects a specific high-impact BES Cyber System for Level 2 review, the system can immediately identify all relevant evidence: baseline configurations from the CMDB, change management tickets documenting authorized modifications, vulnerability scan results from the SIEM, patch management records from the work order system, access logs from PACS showing who had physical or electronic access, training records confirming that authorized personnel completed required CIP training, and incident records showing how the utility responded to any security events affecting that asset. This automated packaging capability reduces the time required to assemble Level 2 responses from days or weeks to hours, while ensuring completeness and maintaining clear lineage from the sample request to each supporting document.

The system is designed to work within the established Regional Entity audit schedules that compliance professionals navigate every audit cycle. ERT requests are typically sent to utilities approximately 120 days before the audit start date, establishing the scope and timing expectations. Utilities have approximately 60 days to populate the ERT workbook and submit their Level 1 response, though specific timelines vary by Regional Entity and audit scope. The system's workflow engine tracks these deadlines, sends notifications

when key milestones approach, and prevents premature submission when mandatory fields remain incomplete. After the Level 1 submission, auditors review the population data and select samples for Level 2 detailed review. These Level 2 requests arrive closer to the audit start date, often with compressed response windows. Throughout the audit period, Request for Information exchanges occur as auditors identify questions that require clarification or request additional evidence beyond the initial submission. The system manages RFI workflows by routing questions to the appropriate subject-matter experts, tracking response deadlines, maintaining conversation history, and linking responses to relevant artifacts in the evidence package. This integrated RFI capability ensures that clarification exchanges remain organized and traceable rather than scattered across email threads and informal conversations.

The pilot program demonstrates three core capabilities specifically aligned with NERC audit mechanics. First, the system automatically populates selected detail tabs to create defensible populations that meet NERC request ID requirements and pass auditor validation. During the mock audit, the volunteer utility will use the system to populate multiple detail tabs—such as BES Assets, Cyber Assets, ESP, and Personnel—with data automatically extracted from source systems. Regional Entity auditors will review these populations using their standard validation procedures, assessing whether the data is complete, internally consistent, and properly classified in accordance with CIP definitions. This demonstration will quantify time savings relative to manual population and validate that automated extraction produces audit-quality evidence. Second, the system automates the packaging and indexing of evidence artifacts for sampled Level 2 items, with clear lineage from sample selection to supporting documentation. When auditors select specific items for Level 2 review during the mock audit, the system will assemble comprehensive evidence packages that include all relevant artifacts, organized with cover sheets explaining the relationship between each document and the sampled item, indexed for rapid navigation, and annotated with metadata showing when each artifact was created, who authored it, and which source system provided it. Third, the system provides rapid question-and-answer capabilities, with citations linking responses to submitted artifacts, supporting both utility RFI preparation and auditor evidence review. The GenAI interfaces will enable compliance staff to query the assembled evidence package using natural language questions—receiving immediate answers with citations to the specific detail tab rows and supporting documents that justify the response.

The system supports the complete CIP ERT detail tab structure as documented in the current NERC CIP Evidence Request Tool User Guide. This includes the BES Assets tab establishing the facility inventory that defines audit scope, the Cyber Asset tabs (CA, Low CA, TCA) documenting the complete population of cyber assets associated with BES facilities along with their impact classifications, the Electronic Security Perimeter tabs (ESP, EAP) defining the network security architecture and perimeter access points, the Physical Security Perimeter tab documenting physical access controls protecting CIP assets, the Personnel tab establishing the population of individuals with authorized access and required CIP training, the BCSI tab documenting how the utility protects sensitive cyber system information, the Cybersecurity Incident tab recording security events and response actions, the Procurement tab tracking vendor risk assessments and supply chain security, and the Reuse and Disposal tab documenting asset sanitization and decommissioning activities. By supporting this complete set of detail tabs rather than a subset, the system enables comprehensive audit preparation and avoids forcing utilities to maintain hybrid manual-automated workflows.

The pilot validates consistency across Regional Entity approaches by testing with auditors from at least two different Regional Entities, ensuring the system accommodates variations in audit tailoring and scope definition while maintaining standardized output formats recognized by all regions. This cross-region validation demonstrates that utilities operating across multiple Regional Entity territories can use a single system instance to prepare for audits under different regional procedures, rather than maintaining separate compliance infrastructures for each region.

This comprehensive alignment with established NERC audit mechanics—from request ID compliance and Level 1/Level 2 structure to audit timing integration and regional consistency—ensures the pilot demonstrates a system that fits naturally into the compliance ecosystem used by utilities and auditors daily. The proposal does not ask participants to adopt unfamiliar workflows or trust unproven methodologies; instead, it automates and accelerates the established processes that have governed NERC compliance audits for years, reducing the manual labor burden while preserving the audit quality and regulatory rigor that protect bulk electric system reliability.

Nine-Month Implementation Timeline

Phase	Timeline	Key Activities
Phase 1	Months 1–2	Pilot Design and Preparation • Participant selection and MOU execution • Mock audit scenario finalization • Data anonymization protocols • Development environment setup • Baseline metrics collection
Phase 2	Months 3–4	Data Integration Development • ETL program development for 14 utility data sources • Data schema mapping (utility → ERT format) • Data quality validation framework • Automated population testing
Phase 3	Months 5–6	GenAI Interface Development • Dual interface implementation (utility and Regional Entity) • Credential-based access control • Natural language query capabilities • Provenance tracking and audit trails

		• User acceptance testing
Phase 4	Month 7	Mock Audit Execution • Mock audit notification and Level 1 population • Auditor team review and sampling • RFI exchange testing • Level 2 evidence assembly and submission • Mock audit closeout
Phase 5	Month 8	Evaluation and Security Assessment • Quantitative metrics analysis • Qualitative feedback collection • Security assessment execution • Gap identification and remediation planning
Phase 6	Month 9	Transition Planning • Production readiness assessment • Scaling strategy development • Regulatory approval pathway definition • Final deliverables and documentation • Industry briefing and lessons learned

Participant Requirements

Volunteer Utility Profile

The pilot requires a utility participant with the following characteristics:

- **Multi-Regional Presence:** Operations spanning multiple Regional Entity territories to test consistency across regulatory approaches (preferred but not required)
- **Mature IT Infrastructure:** Documented databases and APIs for the 14 required source systems (facility database, CMDB, asset management, HR, PACS, SIEM, etc.)
- **Recent Audit Experience:** Completed a compliance audit within the last 12–18 months to enable baseline comparison
- **Resource Commitment:** Dedicated personnel throughout pilot duration, including compliance officer, IT architect/database administrator, and subject matter experts from security, operations, and HR
- **Executive Sponsorship:** VP-level or higher champion with authority to allocate resources and make implementation decisions
- **Data Sharing Authorization:** Legal clearance to use historical audit data in a controlled pilot environment with appropriate anonymization
- **Lessons Learned Commitment:** Willingness to share pilot findings with the broader industry (with appropriate anonymization of sensitive details)

Auditor Team Composition

The pilot requires The pilot will seek 3–4 volunteer auditors with NERC CIP audit experience. Recruiting auditors from more than one Regional Entity is preferred to validate that system outputs are consistent across the ERO Enterprise's varying audit methodologies. Target profile:

- **Regional Diversity:** Representatives from at least two different Regional Entities to validate consistency across audit approaches
- **Experience Mix:** One to two senior audit leads with 5+ years of NERC CIP audit experience, and one to two mid-level auditors with 2–4 years of experience
- **ERT Familiarity:** Direct experience using the current Excel-based ERT in at least two audit cycles
- **Technical Aptitude:** Comfort with new software tools and willingness to provide detailed usability feedback
- **Availability:** Two-week availability for mock audit execution, plus preparatory briefings and post-audit debriefings

- **Documentation Commitment:** Detailed feedback on system usability, data quality, and process improvements

Technical Architecture Overview

System Components

The AI-enhanced ERT Companion system comprises three primary architectural layers that work together to automate the assembly of compliance evidence while maintaining complete audit transparency. The Data Integration Layer extracts and transforms data from 14 utility source systems, establishing linking codes and provenance trails that enable defensible populations. The Application Layer provides the core business logic, including workflow orchestration, GenAI query routing, ERT version management, and a vector database that enables semantic search across utility documentation. The Presentation Layer implements two GenAI interfaces—one for utility personnel across compliance, IT security, operations, and procurement, and one for Regional Entity auditors conducting population analysis, sample selection, and evidence review.

These layers operate within the Retrieval-Augmented Generation (RAG) architecture described in the following section, in which pre-trained language models retrieve and synthesize information from utility-specific documents and structured data, rather than relying on custom model training. This architectural separation enables the system to maintain data sovereignty through on-premises deployment while preserving flexibility to integrate with evolving language models and vector database technologies as the GenAI ecosystem matures.

GenAI Architecture Approach

The system uses a Retrieval-Augmented Generation (RAG) architecture rather than training a custom model. This approach combines pre-trained large language models with a vector database that stores the utility's compliance documentation, operational procedures, and cross-business-unit reference materials. RAG provides domain-specific expertise without requiring custom model training, enables instant updates when procedures change, and maintains complete provenance for every AI-generated response—critical for audit transparency and regulatory confidence.

The RAG architecture retrieves relevant utility-specific documents and structured data at query time and injects them into the LLM's context window alongside the user's question. The model then generates responses grounded in actual utility documentation rather than relying solely on general training knowledge. This approach offers several advantages over custom model training: it eliminates the need for expensive retraining cycles when procedures change, provides explicit citations to source documents that auditors can verify, supports multiple CIP ERT versions simultaneously by treating them as different documents in the retrieval corpus, and avoids the regulatory complexity of explaining what a custom-trained model knows versus what it retrieves from authoritative sources.

For utilities concerned about data sovereignty and security, the system is designed for on-premises deployment within the utility's own datacenter infrastructure. All components—the LLM inference engine, vector database, ETL programs, and GenAI interfaces—can operate entirely within the utility's network perimeter without requiring external API calls or cloud services. This deployment model ensures that sensitive compliance data, BCSI, personnel records, and operational details never leave the utility's control,

addressing both cybersecurity concerns and regulatory requirements around critical infrastructure protection.

The GenAI Orchestration layer supports both on-premises and API-based deployment models. For on-premises deployment—the recommended configuration for utilities prioritizing data sovereignty—the system can operate using self-hosted open-source language models such as Meta's Llama 3 (70B or 405B parameter versions), Mistral Large, or similar models that provide enterprise-grade performance without requiring external API calls. These models run on the utility's GPU infrastructure within its data center, ensuring that no compliance data, queries, or generated responses ever leave the utility's network perimeter. The vector database similarly operates on-premises using solutions like Chroma, Weaviate, or Milvus that provide efficient semantic search capabilities.

For utilities with appropriate data handling agreements and cloud security architectures, the system can alternatively interface with commercial API-based models while maintaining the vector database on-premises. This hybrid approach keeps sensitive documents and structured data within the utility's control while leveraging the advanced reasoning capabilities of commercial foundation models.

The orchestration layer implements model-agnostic interfaces, enabling utilities to switch between different language models or run multiple models in parallel for different use cases without requiring application-level changes. For instance, a utility might use a larger, more capable model for generating complex RFI responses and a smaller, faster model for simple data-lookup queries. The system validates all model outputs against retrieval sources to detect potential hallucinations—flagging responses where the model generates content not supported by retrieved documents—and implements guardrails that prevent disclosure of information beyond the user's role- and clearance-based access permissions.

Data Integration Layer

The ETL data integration layer relies on linking codes to establish relationships between data elements across utility source systems and create the unified view required by the ERT detail tabs. These linking codes serve as the connective tissue that transforms isolated data points into comprehensive evidence of compliance.

The process begins with the facility database, which maintains authoritative records for each BES Asset, including control centers, substations, and generation facilities. Each facility is identified by a unique asset identifier (plant code) that serves as the primary linking key. When populating the BES Assets tab, the ETL program extracts these facility records along with their associated metadata, including location, commission dates, and operational status.

The computer asset management database contains cyber asset records tagged with both unique identifiers and reference codes that link them to the physical facilities where they reside. The ETL program uses these facility reference codes to join cyber asset data with the BES Assets already extracted, establishing which cyber assets belong to which physical locations. This same linking pattern populates multiple ERT tabs—the Cyber Asset tab receives the full inventory with classifications (BCA, EACMS, PACS, PCA). In contrast, the Low CA tab filters for low-impact systems, and the TCA and RM tabs capture transient

cyber assets and removable media, respectively, all linked back to their associated BES Assets through facility codes.

The configuration management database uses a more complex linking structure because it tracks not only individual assets but also their relationships to Electronic Security Perimeters. Each cyber asset record in the CMDB includes an ESP identifier field, allowing the ETL program to construct the network security architecture by grouping assets within their protective boundaries. When populating the CA tab, the program looks up each cyber asset's ESP association, populates the "ESP ID" field, and simultaneously builds the ESP tab by aggregating all assets sharing the same ESP identifier. The CMDB also maintains network addressing schemes and baseline configurations that the ETL program cross-references with cyber asset records to validate IP addressing and connectivity attributes.

Network monitoring systems contribute real-time and historical connectivity data, using IP addresses as their primary linking mechanism. The ETL program matches IP addresses from network monitoring logs to cyber asset records extracted from the asset management database, enriching the CA tab with connectivity details, including External Routable Connectivity status and routable protocol usage. For the ESP tab, the program uses network address ranges to determine which IP address blocks fall within each Electronic Security Perimeter. The EAP (Electronic Access Point) tab requires the most granular linking, in which the program identifies specific network interfaces on EACMS devices that serve as perimeter access points and maps interface identifiers to both the parent cyber asset and the ESP it protects.

Physical access control systems maintain badge reader logs and access authorization records, indexed by employee identifiers and facility location codes. The ETL program uses facility location codes to link physical access points to their associated Physical Security Perimeters when populating the PSP tab, creating records that show which badge readers, biometric scanners, and physical barriers protect each PSP. Simultaneously, the program extracts personnel access logs using employee identifiers as linking keys, feeding the Personnel tab with data about who has unescorted physical access to which facilities. These employee identifiers become the critical link to the human resources system.

The HR system serves as the authoritative source of personnel information, with employee identifiers as the universal key linking hiring records, background investigations, and termination data. The ETL program uses these identifiers to enrich Personnel tab records with employment status, position titles, and termination dates. The training management system uses the same employee identifiers to link training completion records, allowing the program to populate CIP training status, certification dates, and retraining requirements in the Personnel tab. This three-way linkage—PACS providing access patterns, HR providing employment context, and training management providing qualification status—creates complete personnel compliance records.

The document management system presents a different linking challenge because BCSI (BES Cyber System Information) exists as a collection of documents rather than discrete database records. The ETL program uses document classification tags and metadata to identify which documents contain BCSI, then links these documents to the BES Assets and Cyber Systems they describe via embedded asset references or folder taxonomies. When populating the BCSI tab, the program groups documents by protection method and assigns impact ratings based on the referenced cyber systems.

SIEM and incident management systems record security events with timestamps, affected asset identifiers, and incident case numbers as their primary linking codes. The ETL program filters these logs for cybersecurity incidents involving BES Cyber Systems, using asset identifiers to link incident records back to the affected cyber assets and their associated BES Assets. The Cyber Security Incident Response Plan activation records include incident case numbers that the program uses to correlate incident detection, response actions, and resolution, populating the CSI tab with complete incident timelines.

Inventory control and vendor management systems track procurement transactions using purchase order numbers, vendor identifiers, and asset serial numbers. The ETL program links procurement records to cyber assets via serial-number matching or asset-tag cross-references, identifying which vendor products and services were procured for which BES Cyber Systems. The vendor identifier serves as the key for extracting vendor assessment data, contract terms, and service level agreements, which populate the Procurement tab's vendor transition and risk assessment fields.

Work order systems maintain maintenance and disposal records linked to asset tags and work order numbers. When populating the Reuse_Disposal tab, the ETL program searches work order records for disposal, reuse, or decommissioning activities and uses asset tags to match these activities to cyber assets in the CA tab. The work order completion dates provide the temporal data required to show when BCSI sanitization occurred and when assets were released for reuse or disposal.

The change management system serves as a cross-cutting data source, tracking modifications to assets, networks, and security perimeters across the entire infrastructure. Change request tickets reference affected assets, ESPs, PSPs, and personnel, using these identifiers as linking codes. The ETL program queries change records for the audit period and uses these asset references to populate modification-tracking fields across multiple tabs.

This web of linking codes enables the ETL program to construct a complete compliance picture from fragmented operational data. The program does not merely copy data—it performs relationship resolution, validating that linking codes refer to valid entities and flagging orphaned records where a cyber asset references a non-existent ESP or a personnel record shows access to a decommissioned facility. The transformation logic incorporates business rules that understand the semantic meaning of these relationships, ensuring that the integrated data maintains referential integrity and accurately represents the utility's CIP-relevant infrastructure and processes.

Source System Mapping at a Glance

The following table shows the 14 source systems integrated by the ETL layer and the ERT detail tabs that each feeds. Note that SIEM, incident management, inventory control, and vendor management are each distinct source systems contributing to a shared tab.

- Facility database → BES Assets tab
- Computer asset management database → CA, Low CA, TCA, RM tabs
- Configuration management database → CA, ESP tabs
- Network monitoring system → CA, ESP, EAP tabs

- Physical access control system → PSP, Personnel tabs
- Human resources system → Personnel tab
- Training management system → Personnel tab
- Document management system → BCSI tab
- SIEM → CSI tab
- Incident management → CSI tab
- Inventory control → Procurement tab
- Vendor management → Procurement tab
- Work order system → Reuse_Disposal tab
- Change management system → modification tracking across multiple tabs

The ETL layer implements data quality validation, conflict resolution, and provenance tracking to ensure traceability from source systems to populated ERT fields.

Application Layer

Core business logic and data management reside in the application layer, which sits at the heart of the AI-enhanced ERT system and coordinates all system operations. At its core, the ERT Data Store serves as the authoritative repository for all compliance information, maintaining not only the current state of ERT detail tabs but also a complete submission history showing how data evolved throughout the audit preparation process. This database preserves multiple versions of each detail tab, capturing when modifications occurred, who made them, and what triggered the changes, creating a comprehensive audit trail that supports both regulatory review and quality assurance verification.

The Workflow Engine orchestrates the multi-phase audit lifecycle, managing state transitions as the evidence package moves from initial data extraction through utility review, formal submission, auditor sampling, and Level 2 evidence assembly. The engine enforces business rules that govern each phase—for instance, preventing submission until all mandatory fields are populated, locking submitted data to prevent unauthorized modifications, and routing Request for Information exchanges between utility and audit teams. It also manages notification workflows, alerting appropriate personnel when actions require their attention.

GenAI Orchestration provides an intelligent routing layer that connects users' natural-language queries to appropriate language models and validates that responses meet quality standards before presenting them to users. The system implements a Retrieval-Augmented Generation architecture in which user queries trigger semantic search across a vector database containing utility compliance documentation, operational procedures, IT security policies, procurement guidelines, and structured data extracted from all 14 source systems. The retrieval engine identifies the most relevant documents and data records, which are then injected into the language model's context window alongside the user's question. The model generates

responses grounded in these retrieved materials, ensuring that answers reflect actual utility procedures and data rather than generic compliance advice.

Provenance Tracking maintains an unbroken chain of custody for every data element in the system, recording not only what information appears in ERT tabs but also where it originated, when it was extracted, the transformations applied, and which personnel reviewed or approved it. When a cyber asset's IP address appears in the CA tab, the provenance tracking documents confirm that this value originated from the network monitoring system via a specific ETL query executed at a particular timestamp, was validated against the CMDB for consistency, and was reviewed by the utility's network engineering team before submission. For AI-generated responses, provenance tracking captures the complete context, including the user's query, the data sources the AI accessed, the reasoning process it followed, and the confidence level assigned to the response. This granular lineage enables both quality assurance validation and forensic investigation if questions arise about data accuracy or completeness.

The Access Control subsystem enforces role-based permissions that maintain strict separation between utility and audit personnel while enabling appropriate collaboration during different audit phases. The system implements temporal access rules that automatically adjust permissions based on workflow state—utility personnel have read-write access to ERT data before submission, but transition to read-only access after submission, at which point auditors gain access to submitted packages but cannot see utility work in progress or internal deliberations. Within each organization, the access control layer implements hierarchical permissions, with compliance officers having broader access than subject matter experts. Certain sensitive fields, such as network security details or other access-restricted data, may be further limited to specific roles even within the utility. The system logs all access attempts, successful or denied, creating an accountability record that demonstrates appropriate handling of sensitive compliance information throughout the audit lifecycle.

Application Layer Components

- **ERT Data Store:** Database holding all detail tabs, submission history, and audit trails
- **Workflow Engine:** Manages audit lifecycle from pre-submission review through Level 2 evidence packaging
- **GenAI Orchestration:** Routes queries to appropriate language models and validates responses
- **Provenance Tracking:** Maintains complete lineage for all data elements and AI-generated responses
- **ERT Version Management:** Explicit support for multiple CIP ERT versions with schema-driven mapping
- **Access Control:** Role-based permissions enforcing separation between utility and audit personnel

ERT Version Management

The application layer implements explicit version handling to ensure compatibility across NERC CIP ERT releases. Rather than hard-coding ERT formats, the ETL layer uses version-specific configuration files that define how utility data maps to ERT fields—enabling new ERT versions to be supported by updating the configuration rather than modifying the core code.

Version-Specific Templates maintain separate configuration definitions for each supported ERT version, specifying request ID schemas, detail tab structures, mandatory fields, and validation rules. Version Detection and Selection prompts users to specify the CIP ERT version they are responding to upon initialization, ensuring all subsequent data mapping and validation rules align with that version's structure. Schema-Driven Mapping then applies the appropriate configuration to drive automated population.

Migration Support ensures that when NERC releases a new ERT version mid-audit cycle, the system provides mapping assistance to transition in-progress evidence packages from the legacy format to the new format, preserving completed work while adopting updated requirements. Validation and Testing suites for each supported ERT version validate the correct population of all detail tabs, ensuring that version updates do not introduce errors or data loss.

This version-aware architecture ensures that as NERC evolves the CIP ERT to incorporate new standards or modify request structures, the system can adapt without requiring utilities to re-engineer their ETL programs or retrain users on fundamentally different workflows.

Vector Database and Document Corpus

The vector database serves as a semantic search engine, enabling the RAG architecture to retrieve relevant utility-specific knowledge. Document ingestion processes convert compliance documentation, operational procedures, security policies, and other reference materials into vector embeddings—mathematical representations that capture semantic meaning rather than just keyword matching. When a user asks "what are our patch management requirements for high-impact BES Cyber Systems," the retrieval engine identifies documents discussing patch management in the context of high-impact systems based on semantic similarity, even if those exact words do not appear together in the source documents.

The document corpus includes multiple categories of utility knowledge. Compliance documentation encompasses CIP policies and procedures, past audit responses and lessons learned, Regional Entity interpretation documents, and internal compliance training materials. IT security documentation includes network architecture diagrams, change management procedures, vulnerability management policies, and incident response playbooks. Operations documentation covers equipment maintenance procedures, commissioning and decommissioning workflows, and black start restoration plans. Procurement documentation includes vendor risk assessment templates, supply chain security policies, and procedures for managing critical component inventories. Human resources documentation provides personnel access authorization procedures, CIP training curriculum and completion records, and background investigation policies.

Each document is indexed with metadata that enables filtering and access control. Metadata includes document classification (public, internal, BCSI), business unit ownership, effective dates, and version history, related CIP standards, and applicable asset impact levels. This metadata-driven filtering ensures that retrieval results respect information access boundaries—for example, preventing operations personnel from retrieving BCSI documentation they are not authorized to view, or ensuring that queries about specific time periods only retrieve documents that were effective during those periods.

Structured data from the ETL layer integrates with the document corpus via hybrid search capabilities. When a query requires both documents and data, the system retrieves relevant procedure documents from

the vector database while simultaneously querying the structured data store for matching asset records. The response combines procedural guidance with specific asset data, providing actionable intelligence rather than abstract policy statements.

Document corpus management includes version control that supports ERT version-handling requirements. When NERC releases CIP ERT v10 with new request IDs or modified detail tabs, the utility adds the v10 documentation to the corpus without removing the v9 documentation. Queries can specify the version context they require, enabling the system to support utilities that simultaneously prepare for a v10 audit while still referencing v9 documentation for historical comparisons or parallel audit processes across different Regional Entity territories.

Presentation Layer — Dual GenAI Interfaces

The presentation layer implements two GenAI interfaces that serve fundamentally different user communities while sharing the same underlying data infrastructure.

The utility-facing interface supports multiple user personas across different business functions. Compliance staff uses the interface to validate auto-populated data extracted from source systems, ensuring accuracy before submission and identifying gaps requiring manual correction. When audit teams issue Requests for Information during the audit process, compliance personnel use the same interface to review responses, assemble supporting documentation, and submit formal replies via the system's RFI workflow. The interface also guides compliance staff through the evidence package submission process, performs completeness checks, and generates the cryptographically signed package that formally transfers data to the audit team.

IT security personnel interact with the utility-facing interface differently, leveraging its natural language query capabilities to answer operational questions beyond compliance needs. When a new vulnerability is disclosed, security staff can ask "where are all CIP High Critical devices running this specific operating system version?" and receive immediate answers with asset locations, network addresses, and facility assignments. They query access control configurations to understand which personnel have electronic or physical access to specific cyber assets, supporting incident response and insider threat investigations. The interface democratizes access to this information—security analysts do not need specialized knowledge of asset management databases or CMDB query languages, because the GenAI layer translates their natural-language questions into appropriate database queries and presents results in a clear format.

Operations personnel use the interface to compare across facilities and to view equipment inventory. Procurement staff leverages the interface to track critical component inventory levels and monitor vendor transitions, ensuring that supply chain disruptions do not compromise high-impact cyber systems and that vendor risk assessments remain current for all suppliers with access to BES Cyber Systems.

The audit-team-facing interface provides capabilities that accelerate and enhance the compliance review process. Population analysis tools help auditors understand the scope and composition of the utility's BES infrastructure. Evidence review capabilities present submitted documentation with intelligent linking that connects related information across detail tabs. Natural language query capabilities enable auditors to

perform comparative analysis across utilities over time, transforming individual compliance audits into strategic intelligence on the bulk electric system's cybersecurity posture.

Dual Interface Summary

- **Utility-Facing Interface** — supports compliance staff, IT security, operations, and procurement personas; enables data validation, RFI response, evidence package submission, and operational queries
- **Audit-Team-Facing Interface** — provides population analysis, sample selection assistance, evidence review with linked documentation, consistency checking, and natural language comparative analysis

Credential-Based Access Separation

The system enforces strict separation between utility and audit personnel through credential-based access controls that maintain appropriate boundaries while enabling efficient collaboration during different audit phases.

During the pre-submission phase, only utility personnel can access ERT data through their interface. The audit-team-facing interface remains completely inactive. This allows the utility to validate auto-populated data, correct errors, and prepare evidence without external visibility. Once the utility formally submits its evidence package, access permissions change: auditors gain read access to the package via their interface. In contrast, the utility's data transitions to read-only status to prevent unauthorized modifications that could compromise audit integrity.

The Request for Information exchange phase operates in a dedicated RFI workspace, where both parties can view questions and responses. This facilitates transparent communication while maintaining separation of their respective work products. Importantly, the system maintains separate conversation histories for utility and audit team GenAI interactions. This prevents situations where one party's queries or AI-generated insights could inadvertently appear in or influence the other party's interface.

Additional access restrictions apply even within the audit team. Certain sensitive data elements may be restricted based on clearance requirements, ensuring that only appropriately authorized personnel can view the most security-sensitive compliance details. It is worth noting that restrictions on personnel records—such as limitations on Social Security numbers and similar personally identifying information—are governed by privacy and HR policies, not by BCS classification under NERC CIP. These are distinct frameworks, and the system's access controls are designed to honor both. All access attempts, whether successful or denied, are logged to create a complete accountability record demonstrating appropriate handling of sensitive compliance information throughout the audit lifecycle.

Success Metrics and Evaluation Criteria

Quantitative Metrics

Metric	Measurement Method	Target
ERT Completion Time	Compare hours to populate ERT: historical manual vs. AI-assisted	60–70% reduction
Data Quality	Error rate in auto-populated fields validated against source systems	<5% error rate
Query Response Time	Average time from natural language query to complete response	<10 seconds
Cross-Functional Adoption	Number of non-compliant personnel actively using the system	5+ users from different business units
Query Diversity	Range of successful query patterns across business functions	20+ distinct query types
Auditor Satisfaction	Post-audit survey on data quality, completeness, and usability	4.0 / 5.0 average rating

Qualitative Assessment Areas

Beyond quantitative metrics, the pilot evaluation will assess several qualitative dimensions that reflect user experience and system effectiveness.

The usability assessment will examine interface intuitiveness, learning curves across user personas, and feature discoverability. The evaluation team will assess whether compliance staff, IT security personnel, and other business users can perform their tasks efficiently with minimal orientation, without requiring extensive training to become productive.

Workflow integration analysis will determine how well the system fits within existing audit processes and utility operations. The evaluation will examine whether the AI-enhanced ERT feels like a natural extension of current practices or creates friction by forcing users to adapt to rigid new procedures. Successful integration means the system complements established workflows rather than disrupting them.

Data trustworthiness represents a critical factor in user adoption. Through surveys, interviews, and behavioral observation, the assessment will gauge user confidence in AI-generated responses and automated data extraction. The evaluation will identify which factors build or undermine confidence in system accuracy and what trust calibration looks like in practice.

Collaboration effectiveness will be assessed based on the quality of interactions between the utility and audit teams. The assessment will examine whether Request for Information exchanges communicate clearly and whether the submission process flows smoothly. Success means both parties can work efficiently within the system without resorting to external channels to resolve system-related issues.

Cross-functional value will be assessed through testimonials from non-compliance personnel who use the system for operational purposes. IT security staff, operations personnel, and procurement teams will provide feedback on whether the system delivers genuine business value beyond regulatory compliance—validating whether the dual-value proposition materializes in practice or remains theoretical.

Qualitative Assessment Areas

- **Usability:** Interface intuitiveness, learning curve, and feature discoverability across user personas
- **Workflow Integration:** How well the system fits existing audit processes and utility operations
- **Data Trustworthiness:** User confidence in AI-generated responses and automated data extraction
- **Collaboration Effectiveness:** RFI exchange clarity and submission process smoothness
- **Cross-Functional Value:** Non-compliance user testimonials on operational benefits

Security Assessment Scope

The security assessment will examine the system through multiple lenses, evaluating both traditional infrastructure security and AI-specific vulnerabilities that could compromise the integrity of compliance evidence or expose sensitive utility data.

Infrastructure security testing will follow established cybersecurity frameworks to assess foundational protections. The assessment will evaluate authentication mechanisms to ensure only authorized users can access the system, authorization controls to verify that users can perform only permitted actions, and data encryption in transit and at rest. Network segmentation testing will confirm that the pilot environment remains properly isolated from production systems. A comprehensive vulnerability assessment will identify potential weaknesses in the underlying infrastructure, operating systems, databases, and application components.

AI-specific testing addresses risks unique to generative AI systems that traditional security assessments might overlook. The evaluation will measure hallucination rates to quantify how often the AI generates plausible yet incorrect responses unsupported by actual data. Prompt injection resistance testing will attempt to manipulate the AI via carefully crafted queries that bypass safety controls or extract unauthorized information. Context confusion testing will probe whether the AI can be tricked into mixing data between different utilities, users, or audit cycles. Data fabrication testing will assess whether the AI can be induced to generate fictitious compliance evidence that appears legitimate.

On-premises deployment security includes evaluation of the additional attack surface introduced by hosting language models and vector databases on local infrastructure. This includes GPU infrastructure security for model inference, vector database access control validation, model supply chain security confirming that downloaded open-source models match published checksums, and air-gap compliance for utilities requiring

complete network isolation. The assessment will also validate that on-premises deployments can receive security updates and model improvements without requiring persistent internet connectivity.

Data integrity verification will trace information flow from source systems through transformation processes to the final presentation. Provenance verification will confirm that every data element in ERT tabs can be traced back to authoritative source systems with complete lineage documentation. Audit trail completeness testing will ensure that all system actions, user interactions, and data modifications are logged with sufficient detail to support forensic investigation.

Access control verification will test the enforcement of credential-based separation between utility and audit personnel. Separation enforcement testing will attempt to access data across organizational boundaries to confirm that utility personnel cannot view audit team internal notes and vice versa. Privilege escalation testing will assess whether users can gain unauthorized access to higher-privilege functions. BCSI protection testing will verify that access to BES Cyber System Information remains restricted to personnel with appropriate clearances.

Security Assessment Scope

- **Infrastructure Security:** Authentication, authorization, data encryption, network segmentation, and vulnerability assessment
- **AI-Specific Testing:** Hallucination rate measurement, prompt injection resistance, context confusion testing, and data fabrication attempts
- **Data Integrity:** Provenance verification, audit trail completeness, and ETL transformation correctness
- **Access Control Verification:** Separation enforcement, privilege escalation testing, and BCSI protection

Pilot Deliverables

Technical Deliverables

The technical deliverables include the complete system implementation and comprehensive documentation to support broader deployment.

The operational prototype system represents the pilot's primary tangible output: a fully functional AI-enhanced ERT with dual GenAI interfaces serving utility and audit team personnel. These ETL programs automate data extraction from utility source systems and credential-based access controls that enforce appropriate separation between parties. This working system will demonstrate feasibility and provide a concrete foundation for scaling to additional utilities.

The ETL programs and connectors form the critical integration layer that bridges utility source systems with standardized ERT formats. The pilot will deliver complete data extraction, transformation, and loading code for all 14 utility source systems, including facility databases, asset management systems, CMDB, network monitoring, PACS, HR, training management, document management, SIEM, incident management, inventory control, vendor management, work order systems, and change management. Each connector will include configuration documentation that enables other utilities to adapt the code to their specific IT architectures.

Data mapping documentation will provide complete schema translations from the volunteer utility's systems to ERT detail tabs. These documented mappings serve as templates that subsequent utilities can modify for their own database schemas.

API specifications will define standardized interfaces for utility-to-audit-team data exchange, authentication protocols, and workflow management. These specifications describe how evidence packages are cryptographically signed and transmitted, how RFI exchanges are structured and routed, how access tokens are validated and refreshed, and how workflow state transitions trigger notifications. Standard APIs enable interoperability as the system scales across multiple utilities and Regional Entities.

Security architecture documentation will capture the complete system design, including security controls, data flow diagrams, and threat models. This documentation provides transparency into how sensitive compliance data is protected, how credential-based separation is enforced, how audit trails are maintained, and what security assumptions underpin the architecture.

The security assessment report will document findings from an independent evaluation of both infrastructure security and AI-specific vulnerabilities. This report will detail discovered weaknesses, assess their severity and exploitability, and provide prioritized remediation recommendations. The assessment validates that the system meets appropriate security standards for handling sensitive utility compliance data and identifies any gaps that must be addressed before production deployment.

Technical Deliverables

- **Operational Prototype System:** Fully functional AI-enhanced ERT with dual GenAI interfaces, ETL programs, and credential-based access control

- **ETL Programs and Connectors:** Data extraction, transformation, and loading code for all 14 utility source systems with configuration documentation
- **Data Mapping Documentation:** Complete schema mapping from the volunteer utility's systems to ERT detail tabs
- **API Specifications:** Interface definitions for utility-to-audit-team data exchange, authentication, and workflow management
- **Security Architecture Documentation:** System design, security controls, data flow diagrams, and threat model
- **Security Assessment Report:** Independent evaluation of infrastructure and AI-specific vulnerabilities with remediation recommendations

Process Deliverables

The process deliverables translate pilot experience into reusable knowledge, enabling industry-wide adoption and ensuring consistent implementation across utilities.

The updated ERT User Guide will revise existing NERC documentation to reflect AI-enabled workflows and submission processes. This guide will explain how utilities interact with the system to validate auto-populated data, how compliance officers submit evidence packages through the interface rather than uploading Excel files, and how audit teams use the GenAI interface for population analysis and sample selection. The revised guide will serve as the authoritative reference for AI-enhanced audit procedures once the system transitions to production.

The Utility Implementation Playbook provides step-by-step guidance for deploying the system at additional utilities. This playbook will cover prerequisites, including required IT infrastructure and source system access; detailed instructions for data source integration and schema mapping; configuration procedures for adapting ETL programs to different utility environments; and testing protocols to validate that automated data extraction produces accurate results.

Training materials will support both utility personnel and audit teams in learning to use the system. User guides will explain interface features and common workflows for different personas. Video tutorials will demonstrate key tasks. Quick reference cards will provide at-a-glance reminders of frequently used functions. These materials accelerate user adoption by reducing the learning curve identified during usability assessment.

The mock audit report will document the simulated compliance audit conducted during the pilot, including findings, the complete evidence package generated by the system, and a detailed comparison to the baseline manual approach. This report quantifies the efficiency gains achieved, highlights data-quality improvements, and provides concrete evidence of the system's capabilities. The report serves as proof of concept for stakeholders evaluating whether to invest in broader deployment.

The lessons learned document will comprehensively capture pilot insights, challenges encountered, solutions implemented, and recommendations for broader deployment. This document preserves

institutional knowledge about what worked well, what proved more difficult than anticipated, how the team resolved unexpected issues, and what would be done differently in future implementations.

Process Deliverables

- **Updated ERT User Guide:** Revised documentation reflecting AI-enabled workflows and submission processes
- **Utility Implementation Playbook:** Step-by-step guide for deploying the system at additional utilities, including prerequisites, data source integration, configuration, and testing
- **Training Materials:** User guides, video tutorials, and quick reference cards for utility personnel and auditors
- **Mock Audit Report:** Simulated compliance audit findings, evidence package, and comparison to the baseline manual approach
- **Lessons Learned Document:** Comprehensive capture of pilot insights, challenges encountered, solutions implemented, and recommendations for broader deployment

Business Deliverables

The business deliverables provide decision-makers with the financial and strategic information needed to justify investment in broader deployment and navigate the path from pilot to production.

The ROI analysis will quantify the economic value delivered by the AI-enhanced ERT system, supported by pilot data. This analysis will document time savings by comparing the hours required to complete the mock audit with historical manual completion times. Cost avoidance will be calculated based on reduced labor hours at fully loaded personnel rates, fewer clarification cycles with audit teams due to improved data quality, and decreased consultant expenses for audit preparation. Operational benefits will be valued where possible, such as faster incident response enabled by IT security's ability to query asset locations, or improved procurement decisions informed by real-time visibility into critical component inventory.

The scaling cost model will project per-utility deployment costs across three implementation tiers. Tier 1 costs will reflect deployment to large multi-regional utilities with mature IT infrastructure and dedicated implementation teams. Tier 2 costs will cover single-region utilities with moderate IT maturity. Tier 3 costs will apply to smaller utilities with limited IT resources that may leverage shared services models or hosted solutions. For each tier, the model will break down costs, including software licensing, system integration labor, ETL customization, training, and ongoing support.

The regulatory approval pathway will recommend a process for transitioning from pilot to an approved CMEP methodology, including decision points, anticipated timelines, and stakeholder engagement requirements to navigate NERC's governance processes successfully.

The industry adoption roadmap will present a five-year phased deployment strategy, including detailed timelines, resource requirements, and risk mitigation approaches. This roadmap will sequence deployment across utility tiers to manage implementation risk, specify resource needs, and set realistic expectations for stakeholders on the pace and requirements for achieving industry-wide adoption.

Business Deliverables

- **ROI Analysis:** Quantified time savings, cost avoidance, and operational benefits with supporting pilot data
- **Scaling Cost Model:** Projected per-utility deployment costs for Tier 1, Tier 2, and Tier 3 implementations
- **Regulatory Approval Pathway:** Recommended process for transitioning from pilot to approved CMEP methodology
- **Industry Adoption Roadmap:** Phased deployment strategy with timeline, resource requirements, and risk mitigation

Risk Mitigation Strategy

Technical Risks

The pilot faces several technical risks inherent in developing AI-enabled systems that integrate with complex utility IT environments. These risks span data integration challenges, AI reliability concerns, security vulnerabilities, and performance limitations. While each risk carries potential consequences for pilot success, the mitigation strategies outlined below reflect proactive approaches to minimize disruption and maintain project momentum.

The most fundamental technical risk involves ETL integration failures with utility source systems. Enterprise IT environments are notoriously heterogeneous, with databases running different versions, APIs using varying authentication schemes, and data schemas reflecting decades of evolutionary change. Even with careful pre-pilot planning, integration attempts may encounter unexpected obstacles such as undocumented database dependencies, API rate limits, or data-quality issues that prevent clean extraction. Early engagement with utility IT staff and maintaining fallback options for manual data population provides insurance against integration setbacks.

AI reliability represents another critical concern. GenAI systems can hallucinate responses, fabricate data that appears plausible, or provide inconsistent answers to similar queries. In a compliance context where accuracy is paramount, even occasional AI errors could undermine user trust and compromise audit integrity. Mandatory human review gates and comprehensive provenance tracking serve as essential safeguards, ensuring that AI outputs are validated against authoritative sources before becoming part of the official compliance record.

Security vulnerabilities and performance issues round out the technical risk landscape. Discovering security weaknesses late in the pilot could force costly remediation or delay deployment. Similarly, poor performance with large datasets could render the system unusable for utilities with extensive BES infrastructure. The mitigation strategies emphasize secure-by-design principles, early security assessments, and proactive load testing to identify and address issues before they affect the mock audit experience.

Technical Risk Register:

Risk	Impact	Mitigation
ETL integration failures with utility source systems	Delays in automated data population testing	Early data source mapping; fallback to manual population with documented gaps
GenAI hallucinations or data fabrication	Incorrect compliance evidence or audit findings	Mandatory human review gates; provenance links to source data; independent testing
Security vulnerabilities were	Delayed deployment or	Security assessment in Month

identified late in the pilot	remediation costs	8 with a remediation buffer; secure-by-design principles
Performance issues with large datasets	Slow query response times or system timeouts	Load testing during development, database optimization, and caching strategies

Organizational Risks

Organizational risks stem from human factors and institutional dynamics that can derail technical projects even when the technology itself functions properly. These risks involve resource availability, cultural resistance to change, and legal constraints that are outside the development team's direct control. Managing these risks requires strong governance, transparent communication, and careful attention to stakeholder concerns throughout the pilot.

Resource availability remains a persistent challenge for pilot participants juggling competing priorities. Utility personnel committed to the pilot may face unexpected operational demands when equipment failures occur or when regulatory deadlines compress. Auditors volunteering for the mock audit must balance participation with their regular audit schedules and enforcement responsibilities. Without sustained executive sponsorship and designated backup personnel, these inevitable conflicts could lead to schedule slippage or incomplete testing. The mitigation strategy recognizes this reality by building timeline flexibility and ensuring that key roles have identified alternates who can step in when primary participants face competing demands.

User resistance to AI-enabled tools is a subtler but equally consequential risk. Some compliance professionals may view AI automation with skepticism, concerned that it will expose errors in their current processes or threaten their specialized expertise. Others may distrust AI outputs based on publicized failures in other domains or philosophical concerns about algorithmic decision-making in regulatory contexts. Early stakeholder engagement, transparent communication about system capabilities and limitations, and emphasis on AI as an augmentation tool rather than a replacement for human judgment help address these concerns before they calcify into active resistance.

Data governance and legal concerns could prevent the pilot from accessing the real utility data necessary for meaningful testing. Corporate legal departments may object to sharing historical audit information even in anonymized form, citing confidentiality obligations or liability concerns. The memorandum of understanding, explicit data-handling protocols, anonymization procedures, and legal review processes mitigate these risks by establishing clear boundaries and protections that satisfy institutional risk-management requirements while enabling the pilot to proceed.

Organizational Risk Register:

Risk	Impact	Mitigation
------	--------	------------

Participant resource availability fluctuates.	Schedule delays or incomplete testing	Executive sponsorship commitment; backup personnel identified; flexible timeline
User resistance to AI-enabled tools	Low adoption or negative feedback	Early stakeholder engagement, transparent communication, and training emphasis
Data governance or legal concerns	Inability to use real utility data in the pilot	MOU with data handling protocols, anonymization procedures, and legal review

Pilot-Specific Protections

The pilot program incorporates several protective mechanisms that distinguish it from production compliance activities and minimize risk for all participants. These protections enable experimentation and learning without jeopardizing regulatory standing or operational continuity.

Most fundamentally, the mock audit results carry no regulatory weight. They do not affect the volunteer utility's actual compliance status, and any system failures or data quality issues have no bearing on NERC enforcement actions or violation findings. This protection allows both the utility and audit teams to experiment with the system's capabilities and push its boundaries without fear of inadvertent compliance consequences.

The utility maintains full rollback capability throughout the pilot duration. If the prototype system proves unreliable or fails to meet operational requirements, the utility can seamlessly revert to the traditional manual ERT process for its next actual audit. This fallback option ensures that participation in the pilot does not compromise the utility's ability to respond to future audit notifications.

The pilot system operates in an isolated environment, completely separate from the utility's production compliance infrastructure and existing audit-preparation workflows. This segregation ensures that pilot activities cannot interfere with ongoing compliance obligations. The utility's operational systems continue functioning normally, with the pilot ETL programs accessing source databases in read-only mode to prevent inadvertent modifications to authoritative data.

The phased implementation approach provides staged validation opportunities at multiple checkpoints before mock audit execution. During the data integration phase, the utility validates that ETL programs accurately extract information from source systems. During interface development, users test functionality and provide feedback before committing to full-scale adoption. This progressive validation enables early identification and correction of issues—whether technical bugs, data quality problems, or usability concerns—before they affect the mock audit experience.

Governance and Decision-Making

Successful pilot execution requires clear governance structures that coordinate activities across multiple organizations, resolve conflicts efficiently, and maintain accountability throughout the nine-month program. The pilot brings together stakeholders with different priorities and perspectives—Eclectic Technologies leading technical development, volunteer utilities investing resources to improve their processes, auditors from participating utilities evaluating usability and audit quality, and ICS supplier colleagues contributing domain expertise. Without explicit governance mechanisms, these diverse interests could lead to scope creep, unresolved disagreements, or drift from core objectives.

The governance framework establishes three complementary bodies operating at different organizational levels. The Steering Committee provides executive oversight and strategic direction, meeting monthly to review progress, resolve high-level issues, and approve major decisions affecting scope, timeline, or resources. The Technical Working Group handles day-to-day implementation decisions during development phases, meeting weekly to address integration challenges, validate data mappings, and troubleshoot technical obstacles. The User Advisory Group ensures the system meets end-user needs and provides feedback on interface design, workflow integration, and usability during critical development windows.

This three-tier structure balances strategic oversight with the agility needed for technical problem-solving. Steering Committee members have the authority to commit resources and make binding decisions, but are not burdened with implementation details. Technical Working Group members have the expertise to resolve engineering challenges but escalate strategic questions to appropriate decision-makers. User Advisory Group members represent the perspectives of actual system users—compliance officers, auditors, and cross-functional personnel—ensuring that design decisions reflect real-world operational requirements rather than abstract technical preferences.

Clear governance prevents common pilot failures such as mission creep, decision paralysis, or stakeholder disengagement. Each governance body has explicit composition, meeting cadence, and decision-making authority to ensure accountability and maintain momentum throughout the pilot.

Steering Committee

Composition:

- Eclectic Technologies program lead (Chair)
- Volunteer utility executive (CIO, SVP Operations, or equivalent)
- ICS supplier colleague with relevant domain expertise
- Participating utility compliance or engineering lead

Responsibilities:

- Monthly meetings to review progress and resolve strategic issues
- Approve major scope changes or timeline adjustments
- Allocate contingency resources when needed

- Final approval of deliverables and transition to production planning

Technical Working Group

Composition:

- Utility IT architects and database administrators
- Development team engineers
- Subject-matter experts from participating ICS supplier colleagues
- Security assessment team representative

Responsibilities:

- Weekly meetings during development phases (Months 2–7)
- Technical design decisions and architecture refinement
- Data mapping validation and ETL program testing
- Issue tracking and resolution

User Advisory Group

Composition:

- Volunteer utility auditors and compliance officers from participating utilities
- Utility compliance officers
- Subject matter experts from IT security, operations, and other business units

Responsibilities:

- Bi-weekly meetings during interface development (Months 5–6)
- Usability feedback on interface design and workflows
- User acceptance testing participation
- Training material review and validation

Path to Production Deployment

A successful pilot demonstration does not automatically translate into industry-wide adoption. The transition from controlled experiment to operational compliance methodology requires navigating regulatory approval processes, developing realistic scaling strategies, and establishing sustainable support models. This path from pilot to production involves multiple stakeholders, including NERC governance bodies, Regional Entities, hundreds of utilities with varying capabilities, and the broader electric sector community that depends on reliable compliance processes.

The regulatory approval pathway reflects how NERC operates under formal governance structures with established procedures for modifying compliance methodologies. Introducing AI-enabled audit procedures would represent a significant departure from current practice, requiring Board-level approval, Regional Entity endorsement, industry comment, and formal revisions to compliance manuals. Building the pilot evidence base—quantified time savings, auditor-validated evidence quality, and demonstrated regulatory integrity—is the prerequisite for entering that process.

The phased deployment strategy reflects practical realities about utility readiness and implementation capacity. Not all utilities can adopt new technology simultaneously. Large multi-regional utilities with mature IT infrastructures and dedicated compliance teams represent natural early adopters who can absorb implementation challenges and refine deployment approaches. Mid-sized utilities follow once templates and best practices are established. Smaller utilities with limited IT resources may require shared services models or hosted solutions developed after the technology stabilizes.

Sustainability considerations address how the system will be maintained, enhanced, and supported over its operational lifetime. Decisions about which components NERC hosts centrally versus what utilities deploy locally affect long-term costs and upgrade complexity. The role of Regional Entities in training and user support must be defined. Mechanisms for incorporating feedback, releasing updates, and coordinating with CIP standard revisions need to be established. Without sustainable support models, even successful technology deployments deteriorate over time as personnel turn over, requirements evolve, and technical debt accumulates.

Regulatory Approval Pathway

The following pathway describes the steps required to transition from a successful pilot to an approved CMEP methodology. These steps represent a future-state objective; the current program is building the pilot evidence base that would support this progression:

1. **NERC Board of Trustees Briefing:** Present pilot results, ROI analysis, and industry benefits
2. **Regional Entity Endorsement:** Secure support from multiple Regional Entities based on a demonstration of consistency
3. **CMEP Manual Revision:** Update compliance procedures to incorporate AI-enabled ERT option

4. **Industry Comment Period:** Solicit broader utility feedback through the NERC Standards process or equivalent
5. **Final Approval:** NERC Board authorization to deploy as an optional methodology for utilities

Phased Industry Deployment

Tier	Timeline	Target Utilities	Characteristics
Tier 1	Years 1-2	5-10 multi-regional utilities	Mature IT infrastructure, dedicated compliance teams
Tier 2	Years 2-3	20-30 single-region utilities	Moderate IT maturity, willingness to invest
Tier 3	Years 3-5	Smaller utilities	Limited IT resources; shared services model

Support and Sustainability Model

- **NERC-Hosted Components:** GenAI platform, NERC-facing interface, centralized data analytics (optional)
- **Utility-Deployed Components:** ETL programs, utility-facing interface, data integration layer
- **System Integrator Services:** Implementation support, customization, and training for utilities requiring assistance
- **Regional Entity Role:** User support, training coordination, and feedback collection from utilities
- **Ongoing Enhancement:** Annual updates coordinated with ERT version releases and CIP standard revisions

Conclusion and Next Steps

Strategic Value Proposition

The AI-enhanced Evidence Request Tool pilot represents a significant opportunity to modernize NERC compliance processes while simultaneously delivering operational value across utility organizations. By automating data extraction from existing utility systems and providing natural language interfaces to aggregated compliance data, the system can reduce audit preparation time by 60–70%, improve data quality, and enable proactive compliance monitoring. Beyond compliance efficiency, the system democratizes access to critical infrastructure information, enabling IT security personnel to rapidly assess vulnerability exposure, operations staff to track equipment across facilities, and procurement teams to monitor vendor transitions—transforming compliance data from a regulatory obligation into a strategic asset.

The mock audit approach de-risks this innovation by enabling comprehensive testing in a controlled environment without compliance consequences. The protective mechanisms built into the pilot—no regulatory impact, full rollback capability, isolated environment, and staged validation—allow participants to experiment boldly while maintaining operational continuity. Successful pilot execution will demonstrate feasibility, quantify benefits, and build industry confidence in AI-enabled compliance tools. The comprehensive deliverables, including technical specifications, process documentation, and business analysis, will provide a clear roadmap for broader deployment across the ERO Enterprise.

Pilot Resource Requirements

The pilot is structured as a pro bono industry initiative under the Eclectic Technologies governance model, with participating utilities and Regional Entities contributing in-kind resources rather than a centralized program budget. Specific cost commitments depend on the complexity of the volunteer utility's infrastructure, the scope of required ETL integration, and the availability of existing development capacity. These factors will be assessed during participant selection, and a detailed resource and cost estimate will be produced as part of the Month 2 Technical Planning deliverable following MOU execution. Prospective participants should anticipate resource commitments in the following areas: dedicated compliance and IT staff time during development and testing phases; read-only access to production source systems in a controlled environment; infrastructure for the isolated pilot deployment environment; and participation in governance bodies throughout the nine-month program. Utilities and Regional Entities with questions about resource expectations before applying are encouraged to contact the program lead directly.

Immediate Next Steps

6. **Issue Call for Participants:** Distribute pilot announcement to utilities and Regional Entities seeking volunteers (Month 1)
7. **Participant Selection:** Evaluate applications, conduct interviews, and select volunteer utility and auditor team (Months 1–2)

8. **MOU Execution:** Finalize legal agreements covering data handling, intellectual property, and lessons learned sharing (Month 2)
9. **Kickoff Meeting:** Convene all participants, establish governance structure, confirm timeline and deliverables (Month 2)
10. **Technical Planning:** Conduct detailed data source mapping at volunteer utility, finalize mock audit scenario, establish development environment (Month 2)

Contact Information

For additional information about this pilot program or to express interest in participation, please contact:

Tim Roxey

Eclectic Technologies

Email: tim.roxey@gmail.com

Phone/Signal: 410.474.9240

Appendix A — Acronym Glossary

The following acronyms are used throughout this proposal.

Acronym	Definition
AI	Artificial Intelligence
API	Application Programming Interface
BCA	BES Cyber Asset
BCSI	BES Cyber System Information
BES	Bulk Electric System
CIP	Critical Infrastructure Protection
CMDB	Configuration Management Database
CMEP	Compliance Monitoring and Enforcement Program
CSI	Cybersecurity Incident
CSIRP	Cyber Security Incident Response Plan
EACMS	Electronic Access Control or Monitoring System
EAP	Electronic Access Point
ERO	Electric Reliability Organization
ERT	Evidence Request Tool
ESP	Electronic Security Perimeter
ETL	Extract, Transform, Load
GenAI	Generative Artificial Intelligence
GPU	Graphics Processing Unit
LLM	Large Language Model

MOU	Memorandum of Understanding
NERC	North American Electric Reliability Corporation
PACS	Physical Access Control System
PCA	Protected Cyber Asset
PSP	Physical Security Perimeter
RAG	Retrieval-Augmented Generation
RFI	Request for Information
RM	Removable Media
ROI	Return on Investment
SIEM	Security Information and Event Management
TCA	Transient Cyber Asset